

# **SIMATS ENGINEERING**

## **CO3 ASSESSMENT TOOL - 1**

### **Enumeration Analysis**

**COURSE CODE: ITA14**

**COURSE NAME: Ethical Hacking**

---

#### **COURSE OUTCOME COVERED**

***CO3:** Analyse network services using port scanning, ping sweeps, and enumeration techniques across different operating systems to identify vulnerabilities. (BL3)*

*Assessment Tool Weightage: 40%*

---

**QUESTIONS: 5**

**Total Marks:100**

---

#### **Code of Conduct:**

*I **SHAIK ASHA (192473025)** certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

***Signature of the student:***

### RUBRICS FOR CALCULATION

| Criteria                 | Weightage (%) | Level 4 (Exemplary)                                                         | Level 3 (Proficient)                        | Level 2 (Developing)                         | Level 1 (Beginning)                     | Mark |
|--------------------------|---------------|-----------------------------------------------------------------------------|---------------------------------------------|----------------------------------------------|-----------------------------------------|------|
| Conceptual Understanding | 20%           | Demonstrates strong understanding of underlying concepts in the simulation  | Shows good understanding with minor gaps    | Partial understanding; some misconceptions   | Lacks understanding of key concepts     |      |
| Model Design             | 25%           | Develops accurate, well-structured simulation/model independently           | Develops correct model with minor errors    | Model is incomplete or requires guidance     | Unable to develop a proper model        |      |
| Tool Usage               | 20%           | Uses simulation tools effectively with correct setup and execution          | Uses tools with minor errors or guidance    | Limited ability to use tools properly        | Unable to use simulation tools          |      |
| Analysis of Results      | 20%           | Provides clear, logical analysis and meaningful interpretation of results   | Analysis is reasonable with minor gaps      | Superficial analysis; limited interpretation | Unable to analyze or interpret results  |      |
| Documentation            | 15%           | Presents results clearly with proper documentation and structured reporting | Documentation is adequate with minor issues | Poorly organized or incomplete documentation | No proper documentation or presentation |      |

**1. A cyber security consulting company has been contracted to perform an initial security assessment of the publicly accessible server scanme.nmap.org. Before conducting any vulnerability assessment, the client requires a detailed enumeration report. Using Nmap, perform host discovery, TCP port scanning, service version detection, operating system fingerprinting, and default script scanning on scanme.nmap.org. Analyze all identified ports and services, determine their business purpose, and evaluate whether they are necessary for public access. Discuss how a threat actor could utilize the information gathered during enumeration to launch further attacks such as service exploitation, brute-force attacks, or vulnerability discovery. Prepare a technical report summarizing your findings, attack surface analysis, risk assessment, and recommendations for securing the server.**

### **Aim**

To perform comprehensive network enumeration of the publicly accessible host scanme.nmap.org using Nmap and identify its open ports, running services, service versions, operating system information, and potential security risks.

### **Objectives**

- To perform host discovery.
- To identify open TCP ports.
- To detect running services and their versions.
- To perform operating system fingerprinting.
- To perform default script scanning.
- To analyze the identified services and their business purpose.
- To evaluate the public exposure of the services.
- To understand how enumeration information can assist further security testing.
- To recommend suitable security measures.

### **Tool Used**

**Nmap (Network Mapper):** Nmap is a network scanning and security auditing tool used to discover hosts, identify open ports, determine running services and versions, perform operating system detection, and execute NSE scripts.

## **Commands Used**

```
nmap -sn scanme.nmap.org
```

```
nmap -sS scanme.nmap.org
```

```
nmap -sV scanme.nmap.org
```

```
sudo nmap -O scanme.nmap.org
```

```
nmap -sC -sV scanme.nmap.org
```

## **Host Discovery**

Host discovery was performed to determine whether the target was reachable.

```
nmap -sn scanme.nmap.org
```

The scan confirmed that the target host was reachable. Host discovery is an important initial step because it establishes whether the target is active before performing detailed port and service enumeration.

## **TCP Port Scanning**

A TCP SYN scan was performed to identify open TCP ports.

```
nmap -sS scanme.nmap.org
```

The scan identified the TCP ports that were accessible from the scanning system. Open ports indicate services that are accepting network connections.

## **Port Analysis**

| Port | Protocol | Service | Purpose                      | Security Significance                                                          |
|------|----------|---------|------------------------------|--------------------------------------------------------------------------------|
| 22   | TCP      | SSH     | Secure remote administration | Should be restricted and protected with strong authentication                  |
| 80   | TCP      | HTTP    | Web service                  | Public exposure is expected for a web server but requires secure configuration |

The exact ports and service states should be reported according to the Nmap output obtained during the practical session.

### **Service Version Detection**

The following command was used:

```
nmap -sV scanme.nmap.org
```

Service version detection identifies the applications running behind the discovered ports. This information is useful during security assessment because different software versions may have different vulnerabilities and configuration requirements.

The detected service information provides the security tester with a better understanding of the technologies exposed by the server.

### **Business Purpose of Identified Services**

#### **SSH – Port 22**

SSH is normally used for secure remote administration of Linux and Unix-based systems. It allows administrators to remotely manage the server.

If remote administration is required, SSH may be necessary. However, exposing it to the entire Internet increases the authentication attack surface. Access should therefore be restricted whenever possible.

#### **HTTP – Port 80**

HTTP is used to provide web content to users. If the server is intentionally hosting a publicly accessible website, HTTP may be required.

However, web services are common targets for vulnerability discovery. The application and underlying web server should therefore be regularly updated and securely configured.

## **Attack Surface Analysis**

The attack surface consists of all network-accessible services and applications exposed by the host.

An attacker performing reconnaissance could use the enumeration information to:

- Identify accessible network services.
- Determine the technologies used by the server.
- Identify service versions.
- Search for known vulnerabilities affecting detected software.
- Identify authentication services.
- Determine potential targets for further security testing.
- Identify unnecessary or weakly protected services.

For example, identifying SSH could indicate the presence of a remote administration interface, while identifying a web service could direct further assessment toward the web application and web server configuration.

Enumeration does not itself prove that a vulnerability exists. It provides information that can be used to prioritize subsequent authorized security testing.

## **Risk Assessment**

| Service          | Risk Level | Reason                                                                                          |
|------------------|------------|-------------------------------------------------------------------------------------------------|
| SSH              | Medium     | Provides remote administration and may be targeted for authentication attacks if poorly secured |
| HTTP             | Medium     | Publicly accessible web services can contain application or configuration vulnerabilities       |
| Host information | Low–Medium | Information about services and technologies can assist reconnaissance                           |

The final risk level depends on the actual service versions, configurations, authentication controls, and vulnerabilities identified during subsequent assessment.

## **Recommendations**

1. Disable unnecessary network services.
2. Restrict SSH access to trusted IP addresses or management networks.
3. Use strong passwords or, preferably, SSH key-based authentication.
4. Disable unnecessary SSH authentication methods.
5. Keep SSH and web-server software updated.
6. Use HTTPS for sensitive web communications.
7. Apply firewall rules to limit unnecessary external access.
8. Monitor authentication attempts and suspicious network activity.
9. Conduct regular vulnerability assessments.
10. Follow the principle of least privilege when exposing services.

## **Conclusion**

Nmap provided useful information about the publicly accessible server, including host availability, open ports, services, service versions, operating-system characteristics, and additional information obtained through NSE scripts. This enumeration information allows a security professional to understand the server's attack surface and prioritize further authorized security testing. Restricting unnecessary services, securing remote administration, maintaining updated software, and applying firewall controls can reduce the risk associated with public exposure.

**2, The security team has deployed a deliberately vulnerable Linux server, 192.168.56.101 (Metasploitable 2), in an isolated laboratory environment to train penetration testers. As part of the pre-engagement reconnaissance phase, use Nmap to perform comprehensive enumeration of 192.168.56.101. Identify all open ports, running services, service versions, and operating system information. Analyze the purpose of each service and determine which services could provide potential entry points for an attacker. Categorize the discovered services into High, Medium, and Low risk levels based on their exposure and functionality. Explain how the enumeration results could guide a penetration tester in selecting potential attack vectors and exploitation strategies.**

## **Aim**

To perform comprehensive enumeration of the deliberately vulnerable Metasploitable 2 Linux server at 192.168.56.101 using Nmap and identify its open ports, services, versions, operating system information, potential entry points, and associated security risks.

## **Objectives**

- To discover the active host.
- To identify all accessible TCP ports.
- To identify running services and versions.
- To determine operating system information.
- To analyze the purpose of each service.
- To classify services according to risk.
- To identify potential attack surfaces.
- To understand how enumeration guides authorized penetration testing.

## **Tool Used: Nmap**

## **Commands Used**

```
nmap -sn 192.168.56.101
```

```
sudo nmap -sS -p- 192.168.56.101
```

```
nmap -sV 192.168.56.101
```

```
sudo nmap -O 192.168.56.101
```

```
sudo nmap -sC -sV -p- 192.168.56.101
```

## **Host Discovery**

The following command was used:

```
nmap -sn 192.168.56.101
```

The target responded to host discovery, confirming that the Metasploitable 2 system was active and reachable within the isolated laboratory network.

### **Comprehensive Port and Service Enumeration**

The following scan was used to identify TCP ports and services:

```
sudo nmap -sS -sV -p- 192.168.56.101
```

Metasploitable 2 is intentionally designed with numerous vulnerable and outdated services. Therefore, multiple network services may be visible.

**Commonly observed services include:**

| Port | Service                | Purpose                              | Risk   |
|------|------------------------|--------------------------------------|--------|
| 21   | FTP                    | File transfer                        | High   |
| 22   | SSH                    | Secure remote administration         | Medium |
| 23   | Telnet                 | Remote administration                | High   |
| 25   | SMTP                   | Email transfer                       | Medium |
| 53   | DNS                    | Name resolution                      | Medium |
| 80   | HTTP                   | Web server                           | High   |
| 111  | RPC                    | Remote procedure calls               | High   |
| 139  | NetBIOS                | Windows/network file-sharing support | High   |
| 445  | SMB                    | File and printer sharing             | High   |
| 3306 | MySQL                  | Database service                     | High   |
| 5432 | PostgreSQL             | Database service                     | High   |
| 8180 | HTTP Proxy/Web service | Web application service              | High   |

The exact services and versions should be taken from the actual Nmap output.

### **Risk Classification**

#### **High-Risk Services**

- FTP
- Telnet

- HTTP
- RPC
- SMB/NetBIOS
- MySQL
- PostgreSQL
- Other outdated or unauthenticated services identified during scanning

These services provide potentially significant attack surfaces because they can expose remote functionality, authentication mechanisms, databases, or file-sharing capabilities.

### **Medium-Risk Services**

- SSH
- SMTP
- DNS

These services can be legitimate and necessary, but their configuration and access controls should be reviewed.

### **Low-Risk Services**

Services with limited functionality and appropriately restricted access can generally be considered lower risk. Risk classification must always consider the actual configuration and exposure.

### **How Enumeration Guides Penetration Testing**

The enumeration results help a penetration tester prioritize potential attack vectors.

For example:

- FTP results can lead to an assessment of authentication and file-transfer configuration.
- SSH results can lead to an assessment of authentication controls.
- HTTP results can lead to web application security testing.
- SMB results can lead to assessment of file-sharing permissions.
- Database services can lead to authentication and access-control assessment.
- Service versions can be compared against known security advisories.

The tester should perform these activities only within the authorized scope of the assessment.

### **Recommendations**

- Disable unnecessary services.
- Replace Telnet with SSH.
- Restrict database services to trusted hosts.
- Apply firewall rules.
- Remove anonymous access where unnecessary.
- Use strong authentication.
- Update outdated services.
- Restrict SMB access.
- Monitor authentication attempts.
- Segment critical services from general user networks.

### **Conclusion**

The enumeration of Metasploitable 2 demonstrates how a system with numerous exposed services can have a large attack surface. Nmap helps identify the services that require further investigation. The deliberately vulnerable configuration makes it particularly suitable for penetration-testing training. In a production environment, unnecessary services should be disabled, outdated software should be upgraded, and network access should be restricted according to the principle of least privilege.

**3, A financial organization wants to assess the security posture of a Windows workstation located at 192.168.56.102 before connecting it to the production network. Using Nmap, enumerate 192.168.56.102 to identify active ports, network services, file-sharing protocols, remote management services, and operating system details. Analyze whether the discovered services comply with the principle of least privilege and identify any services that may unnecessarily increase the attack surface. Discuss how an attacker could leverage the identified services for reconnaissance, lateral movement, or unauthorized access. Based on your findings, propose a set of security hardening measures to improve the system's resilience against cyberattacks.**

## **Aim**

To enumerate the Windows workstation at 192.168.56.102 using Nmap and identify active ports, file-sharing protocols, remote-management services, operating-system information, and unnecessary services that may increase the attack surface.

## **Objectives**

- **To identify active ports.**
- **To detect Windows network services.**
- **To identify file-sharing services.**
- **To identify remote-management services.**
- **To determine operating-system information.**
- **To evaluate the principle of least privilege.**
- **To identify potential risks.**
- **To recommend security hardening measures.**

## **Commands Used**

```
nmap -sn 192.168.56.102
```

```
sudo nmap -sS -p- 192.168.56.102
```

```
nmap -sV 192.168.56.102
```

```
sudo nmap -O 192.168.56.102
```

```
sudo nmap -sC -sV 192.168.56.102
```

## **Host Discovery**

The host discovery scan was used to verify that the Windows workstation was active.

```
nmap -sn 192.168.56.102
```

The system responded to the scan, confirming that the workstation was reachable on the laboratory network.

## **Port and Service Enumeration**

The TCP port scan was performed to identify accessible services.

Typical Windows-related services may include:

| Port | Service | Purpose                                | Security Risk |
|------|---------|----------------------------------------|---------------|
| 135  | MSRPC   | Windows remote procedure communication | Medium–High   |
| 139  | NetBIOS | Legacy Windows networking              | High          |
| 445  | SMB     | File and printer sharing               | High          |
| 3389 | RDP     | Remote desktop administration          | High          |

The exact ports and services must be based on the actual Nmap results.

## **File-Sharing Services**

### **SMB – Port 445**

SMB is commonly used for Windows file and printer sharing.

SMB exposure can increase the attack surface because it provides network-accessible file-sharing and authentication functionality.

Security controls should ensure that only authorized users can access shared resources.

### **NetBIOS – Port 139**

NetBIOS supports older Windows networking functionality.

If not required, legacy NetBIOS services should be disabled or restricted to reduce unnecessary exposure.

Remote Management

### **RDP – Port 3389**

Remote Desktop Protocol provides remote graphical access to Windows systems.

Although useful for system administration, unrestricted RDP exposure can significantly increase the attack surface.

Access should be restricted to trusted management networks or through a secure remote-access mechanism.

### **Operating System Detection**

```
sudo nmap -O 192.168.56.102
```

The scan was used to identify the operating-system family and possible Windows version.

Operating-system information helps administrators determine whether the workstation is using an appropriate and supported operating system.

### **Principle of Least Privilege**

The principle of least privilege states that users and services should receive only the permissions necessary to perform their intended functions.

A workstation should not expose services unless there is a legitimate requirement.

For example:

- SMB should be enabled only when file or printer sharing is required.
- RDP should be restricted to authorized administrators.
- Legacy NetBIOS should be disabled when unnecessary.
- Remote management should be restricted to trusted networks.

### **Potential Attacker Use**

An attacker could use discovered services for:

- Identifying the Windows operating-system version.
- Discovering network-sharing services.
- Identifying remote-management interfaces.
- Mapping available network resources.
- Supporting lateral-movement attempts after an initial compromise.

- Searching for vulnerabilities affecting exposed services.

Enumeration provides information for security assessment but does not by itself demonstrate successful unauthorized access.

### **Security Hardening Measures**

1. Disable unnecessary services.
2. Restrict SMB access using firewall rules.
3. Disable legacy NetBIOS where it is not required.
4. Restrict RDP to authorized networks.
5. Use strong authentication.
6. Enable multi-factor authentication where supported.
7. Apply Windows security updates regularly.
8. Use host-based firewall rules.
9. Disable unnecessary shared folders.
10. Review user and administrator privileges.
11. Monitor failed authentication attempts.
12. Segment workstations from sensitive production systems.

### **Conclusion**

The Nmap enumeration of the Windows workstation provides visibility into the services that would be accessible before the system is connected to the production network. File-sharing and remote-management services require particular attention because they can significantly increase the attack surface. Applying least-privilege principles, restricting remote access, disabling unnecessary services, and maintaining security updates can improve the workstation's resilience.

**4. An organization hosts a web application on 192.168.56.103 (OWASP Juice Shop Server) and plans to conduct a full penetration test. Before the testing phase begins, the security team must understand the server's network exposure. Using Nmap, perform a detailed enumeration of 192.168.56.103, including host discovery, port scanning, service version detection, operating system fingerprinting, and web service identification. Analyze the discovered services and determine how they support the hosted web**

**application. Evaluate the risks associated with exposed web services, administrative interfaces, and supporting services. Explain how the information gathered during enumeration could be used to identify potential vulnerabilities in the web application environment and recommend measures to minimize exposure**

### **Aim**

To perform detailed network enumeration of the OWASP Juice Shop server at 192.168.56.103 and identify its network exposure, web services, supporting services, operating system information, and potential security risks.

### **Objectives**

- To perform host discovery.
- To identify open ports.
- To detect services and versions.
- To identify web services.
- To perform operating-system fingerprinting.
- To analyze services supporting the web application.
- To identify potential exposure.
- To recommend security controls.

### **Commands Used**

```
nmap -sn 192.168.56.103
```

```
sudo nmap -sS -p- 192.168.56.103
```

```
nmap -sV 192.168.56.103
```

```
sudo nmap -O 192.168.56.103
```

```
sudo nmap -sC -sV 192.168.56.103
```

## **Host Discovery**

The host discovery scan confirmed whether the Juice Shop server was active on the laboratory network.

```
nmap -sn 192.168.56.103
```

## **Port Enumeration**

The following command was used:

```
sudo nmap -sS -p- 192.168.56.103
```

The scan identifies all accessible TCP ports and provides an overview of the server's network exposure.

A web application server commonly exposes an HTTP or HTTPS service.

| Port          | Service   | Purpose                | Risk   |
|---------------|-----------|------------------------|--------|
| 80            | HTTP      | Web application        | High   |
| 443           | HTTPS     | Secure web application | High   |
| [Actual port] | [Service] | [Purpose]              | [Risk] |

Only the ports actually identified during the scan should be included in the final practical observation table.

## **Web Service Identification**

Service detection was performed using:

```
nmap -sV 192.168.56.103
```

The scan helps identify the web server technology and version.

The web service is the primary network interface for the Juice Shop application. Because web applications accept requests from users, they require careful security testing and configuration.

## **Supporting Services**

The web application may depend on additional components such as:

- Web server.
- Application runtime.
- Database server.
- Network configuration services.
- Administrative interfaces.

These components can introduce additional attack surfaces if unnecessarily exposed to the network.

## **Risk Analysis**

### **Web Service – High Risk**

The web application is intentionally exposed to users and therefore represents the primary attack surface.

Potential areas requiring authorized security testing include:

- Authentication.
- Authorization.
- Input validation.
- Session management.
- Access control.
- Security configuration.
- Outdated dependencies.

### **Administrative Interfaces – High Risk**

If administrative interfaces are exposed to general networks, attackers may attempt to discover them and target authentication or configuration weaknesses.

Administrative interfaces should be restricted to authorized management networks.

## Supporting Services – Medium to High Risk

Supporting services should not be publicly accessible unless they are required.

For example, a database normally does not need to accept direct connections from arbitrary external hosts when it is only serving the local application.

### **How Enumeration Helps Vulnerability Identification**

The enumeration results provide information about:

- Web-server technology.
- Service versions.
- Open network ports.
- Operating-system characteristics.
- Supporting network services.

A penetration tester can use this information to determine which components require further authorized vulnerability assessment.

### **Recommendations**

1. Expose only required web services.
2. Disable unnecessary network services.
3. Restrict administrative interfaces.
4. Keep the web server and application dependencies updated.
5. Use HTTPS for protected communication.
6. Restrict database access to the application server.
7. Apply firewall rules.
8. Implement strong authentication.
9. Monitor application and server logs.
10. Regularly conduct vulnerability assessments.
11. Segment the application environment from other systems.
12. Follow the principle of least privilege.

## **Conclusion**

Nmap enumeration provides a clear understanding of the network exposure of the OWASP Juice Shop server. The web service represents the primary attack surface, while administrative and supporting services may create additional risks if unnecessarily exposed. Restricting services, protecting administrative interfaces, updating software, and applying network segmentation can minimize the server's exposure.

**5. The network gateway device at 192.168.56.1 serves as the primary access point between the internal laboratory network and external networks. The network administrator suspects that unnecessary management services may be exposed. Using Nmap, conduct a comprehensive enumeration of 192.168.56.1, including port scanning, service detection, operating system fingerprinting, and script-based enumeration. Identify all exposed management interfaces, network services, and accessible resources. Analyze the security implications of exposing services such as SSH, Telnet, SNMP, HTTP, or HTTPS management interfaces. Discuss how attackers could exploit misconfigured management services to gain unauthorized access to the network infrastructure. Based on your analysis, recommend security controls and best practices to secure the gateway device and reduce the risk of compromise.**

## **Aim**

To perform comprehensive enumeration of the laboratory network gateway at 192.168.56.1 using Nmap and identify exposed management interfaces, network services, operating-system information, and potential security weaknesses.

## **Objectives**

- To identify open ports.
- To detect network services.
- To identify management interfaces.
- To perform service-version detection.
- To perform operating-system fingerprinting.
- To perform script-based enumeration.
- To analyze the security implications of exposed management services.

## **Commands Used**

```
nmap -sn 192.168.56.1
```

```
sudo nmap -sS -p- 192.168.56.1
```

```
nmap -sV 192.168.56.1
```

```
sudo nmap -O 192.168.56.1
```

```
sudo nmap -sC -sV 192.168.56.1
```

## **Host Discovery**

```
nmap -sn 192.168.56.1
```

The host discovery scan was used to determine whether the gateway was active and reachable.

## **Port Enumeration**

```
sudo nmap -sS -p- 192.168.56.1
```

The scan identifies the TCP ports exposed by the gateway.

**Potential management services include:**

| Port | Service | Purpose                       | Risk        |
|------|---------|-------------------------------|-------------|
| 22   | SSH     | Secure remote administration  | Medium      |
| 23   | Telnet  | Remote administration         | High        |
| 80   | HTTP    | Web-based management          | High        |
| 443  | HTTPS   | Secure web management         | Medium      |
| 161  | SNMP    | Network monitoring/management | Medium–High |

## **Security Implications**

Exposing management services creates a significant risk because these interfaces can provide administrative functionality.

An attacker who identifies management services may attempt to:

- Identify the device and its software.
- Discover configuration information.
- Determine authentication mechanisms.
- Search for known vulnerabilities.
- Attempt unauthorized authentication.
- Identify network-management information.
- Use a compromised gateway as a stepping stone toward other systems.

Successful compromise of a gateway could have a significant impact because the device controls communication between network segments.

### **Risk Classification**

| Service            | Risk            | Reason                                                                         |
|--------------------|-----------------|--------------------------------------------------------------------------------|
| Telnet             | High            | Unencrypted remote administration                                              |
| HTTP<br>Management | High            | Potentially exposes administrative interface                                   |
| SNMP               | Medium–<br>High | May disclose network/device information                                        |
| SSH                | Medium          | Secure but provides remote administration                                      |
| HTTPS              | Medium          | Encrypted but still requires strong authentication and<br>secure configuration |

### **Security Recommendations**

1. Disable Telnet completely.
2. Use SSH for secure remote administration.
3. Restrict SSH access to trusted management networks.
4. Disable HTTP management when HTTPS is available.
5. Use strong HTTPS configurations.
6. Disable unnecessary management interfaces.
7. Change default administrator credentials.
8. Use strong and unique passwords.

9. Enable multi-factor authentication where supported.
10. Restrict SNMP access to authorized monitoring systems.
11. Replace insecure SNMP configurations with secure alternatives where supported.
12. Apply firmware and security updates regularly.
13. Configure firewall and access-control rules.
14. Monitor management login attempts.
15. Use network segmentation to isolate infrastructure-management interfaces.
16. Follow the principle of least privilege.

## **Conclusion**

Enumeration of the gateway provides important information about the network's externally accessible management interfaces and services. Services such as Telnet, HTTP management, SSH, HTTPS, and SNMP must be carefully controlled because compromise of a gateway can affect the security of the entire network. Disabling unnecessary services, restricting management access, using secure protocols, applying strong authentication, updating firmware, and implementing network segmentation can significantly reduce the risk of gateway compromise.